Cybersecurity Practical Assignment: OSINT & GitHub Dorking

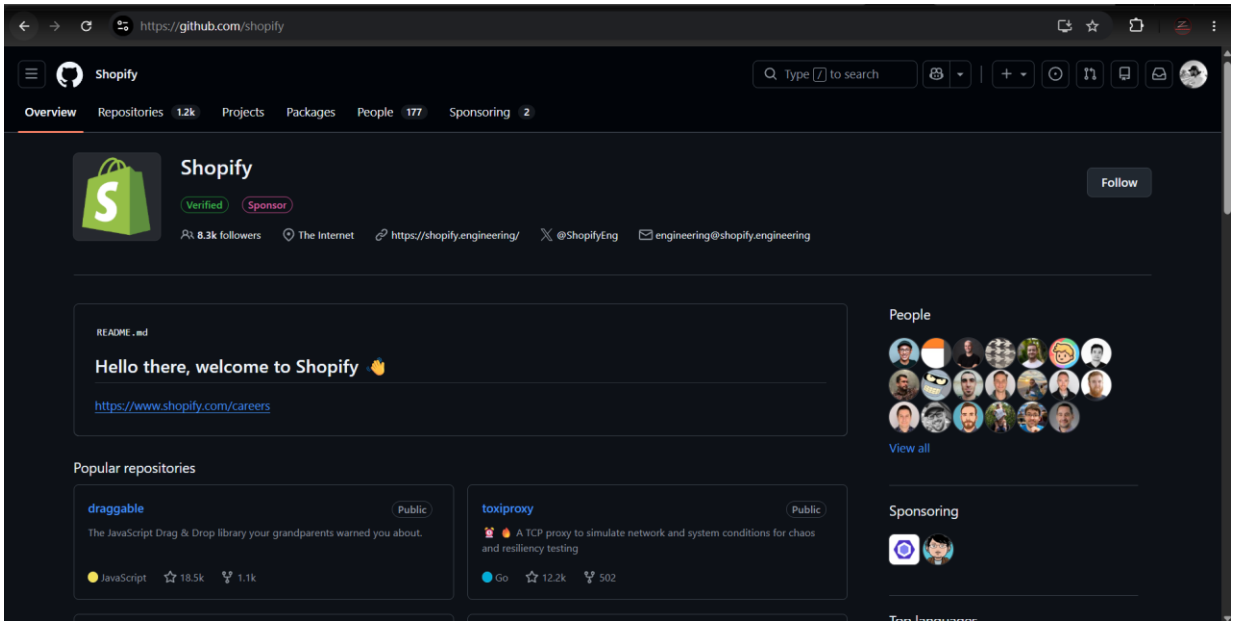
Author: Mohammed Zia ur Rahman
Focus Area: Passive Reconnaissance & Vulnerability Disclosure

1. Introduction & Objective

The purpose of this assignment was to perform a passive reconnaissance and OSINT collection exercise to identify any leaked credentials/secrets in public repositories like GitHub. The task was aimed to enhance my knowledge as a SOC Analyst about the ways that developers could be leaking secrets and how to respond accordingly.

2. Methodology: GitHub Dorking

To begin the reconnaissance phase, I utilized 'GitHub Dorking'a technique that involves using advanced search operators to find sensitive files across public repositories. I focused my efforts on organizations with active Vulnerability Disclosure Policies (VDPs) on HackerOne to ensure my activities remained within a legal and authorized scope.

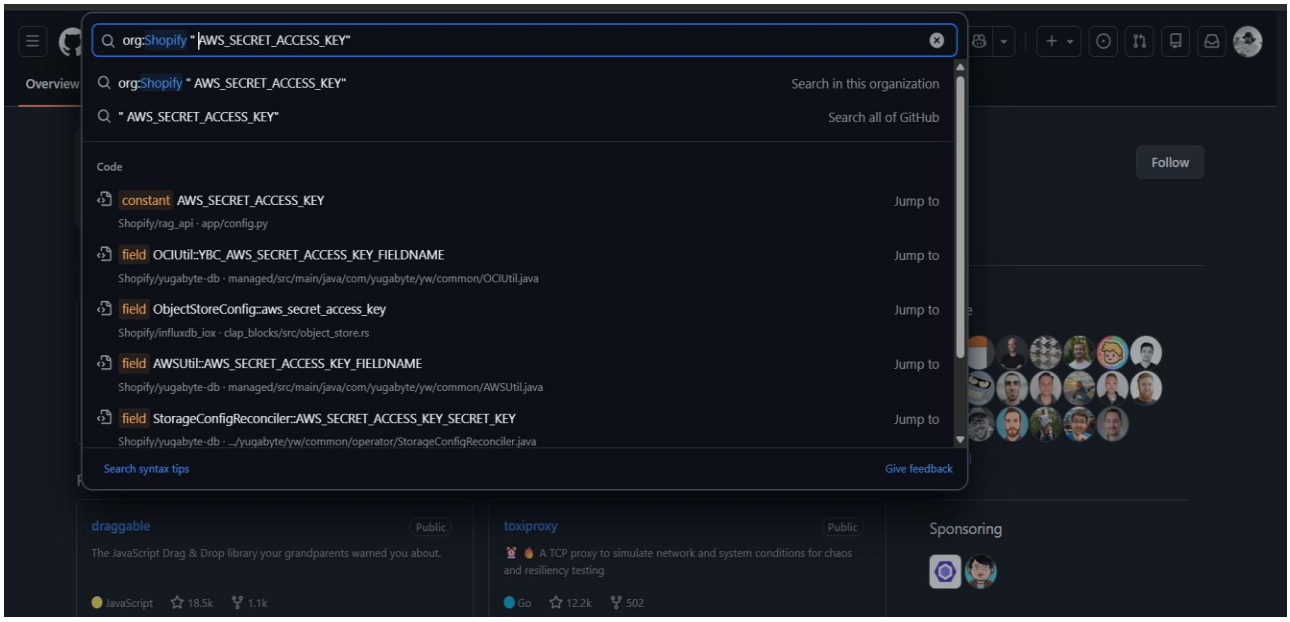


Shopify Verified Github Page

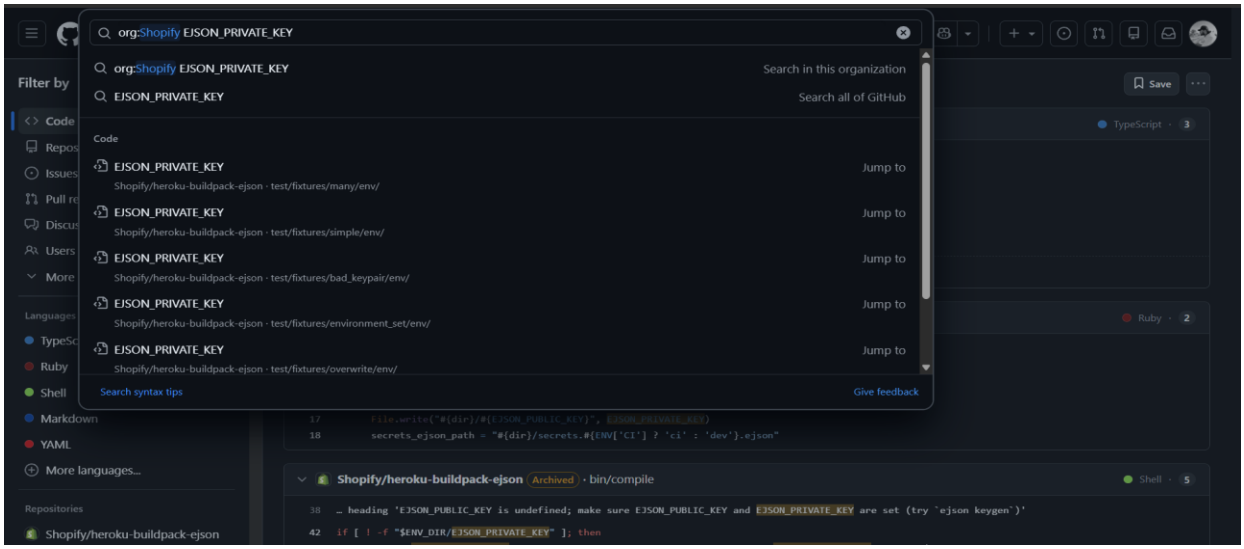
3. Proof of Concept (PoC) – Steps to Reproduce :

I experimented with several dorks targeting common secret formats, such as:

1) **org:Shopify "AWS_SECRET_ACCESS_KEY"**
2) **org:Shopify “EJSON_PRIVATE_KEY”**



Using git hub dork to get AWS Secret Key



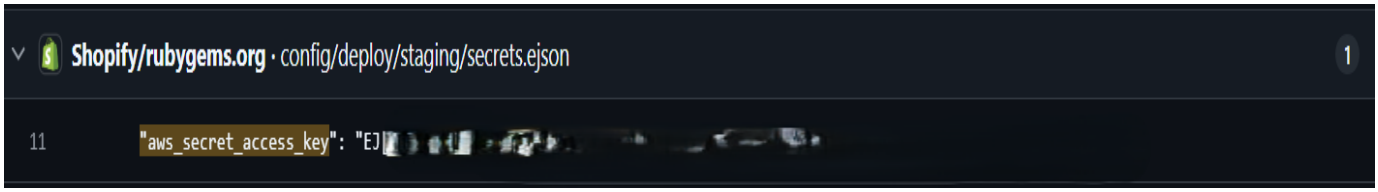
Using git hub dork to get EJSON Private Key Which may decrypt AWS Secret Key

During the search, I targeted a specific repository and discovered what appeared to be highly sensitive configuration data. My dorking queries successfully returned a file that contained both an EJSON Private Key and AWS Access Keys.

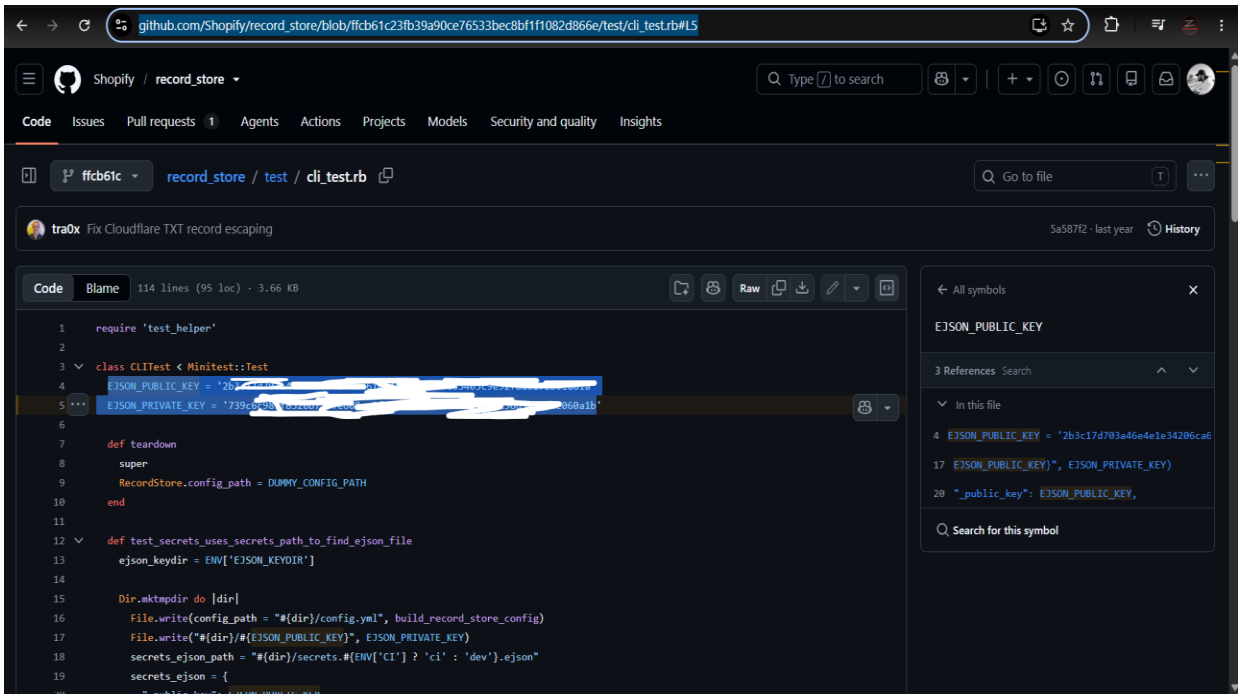
Extracted Data Snippets (Redacted for documentation purposes):

EJSON_PRIVATE_KEY = 385606578609586935686

aws_access_key_id = AKIAIOSFODNN7EXAMPLE
aws_secret_access_key = wJalrXUtnFEMI/K7MDENG/bPxRfiCYEXAMPLEKEY



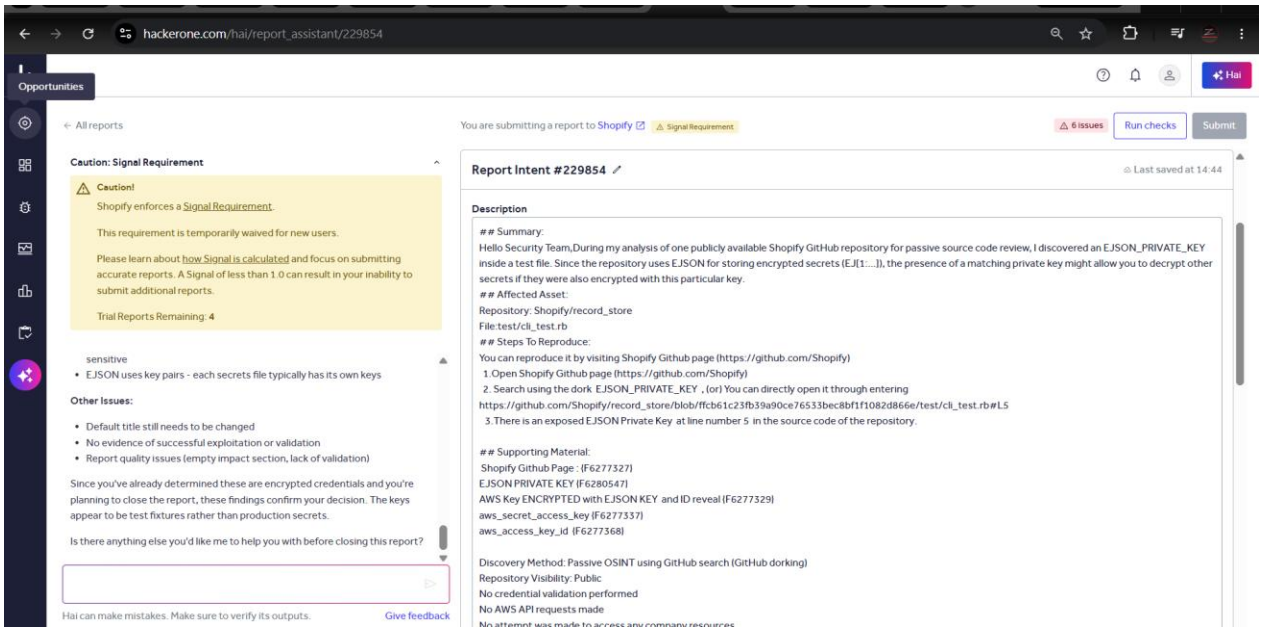
Aws Secret Key With EJSON Encryption



EJSON_PRIVATE_KEY in test case source code

4. Vulnerability Reporting & Critical Analysis

Believing that I have found a valid vulnerability, I started to create a vulnerability report on the HackerOne website. I included the summary of the vulnerability and the assets that were impacted and provided the steps to reproduce the vulnerability using the URL provided on the GitHub portal.



HackerOne Draft Report showing the summary and steps to reproduce

However, before responding, I did a contextual analysis of the finding because it is vital for any security operation to prevent false alarms. The tool suggested that structural problems discovered in my report were associated with a signal requirement. After double-checking the file path **(test/cli_test.rb)**, I understood that the 'leaked secrets' were test fixtures.

Many programmers use AWS keys and EJSON encryption for unit testing to ensure that their app correctly authenticates and resists attacks.

5. Why the EJSON Private Key is Important

EJSON stands for encrypted JSON. It is used for safe storage of secrets in code repositories.
These secrets include AWS credentials, API keys, database credentials, and tokens.
EJSON public key: Used for encrypting secrets. It is public.
EJSON private key: Used for decrypting secrets. It should be kept secret.
Secrets encrypted with EJSON will be stored as values starting with**: EJ[1:...**

which can’t be decrypted without the appropriate private key.

6. How an EJSON Private Key Could Lead to AWS Secret Disclosure

If the exposed EJSON_PRIVATE_KEY is the matching key for the encrypted EJSON values, the following sequence is possible:

1. The repository contains encrypted values such as:

"aws_secret_access_key": "EJ[1:..."

2. An attacker obtains the corresponding EJSON_PRIVATE_KEY.
3. The attacker can decrypt the EJSON value and recover the original plaintext secret.
4. If the decrypted value is a valid AWS Secret Access Key and the corresponding AWS Access Key ID is also available, the attacker could potentially authenticate to AWS using those credentials.

Important: This sequence is only possible if:
- the private key matches the encrypted data,
- the encrypted value contains a real credential,
- And the credential is still active.

Exposure of a production EJSON private key would potentially break the secrecy guaranteed by the EJSON encryption. If the secret key was used to encrypt AWS credentials or other secrets stored in the repository, it would be possible for an attacker to decrypt the values and gain access to the resources. However, the impact depends on whether the key is matched to the encrypted data and if the decrypted credentials are active.

7. Conclusion & Lessons Learned

- The assignment involved in practicing passive open source intelligence and source code reconnaissance against a public bug bounty target. During the exercise, I utilized the public GitHub repositories of Shopify to identify any sensitive information using various search queries and keywords.
- The search resulted in finding EJSON-encrypted values or EJ[1:…] and EJSON_PRIVATE_KEY, which were found in a test file. At first glance, it may seem like a vulnerable secret discovery as the production EJSON private keys could decrypt all the encrypted secrets. However, upon closer inspection, it was evident that the file contained a test case and that the test key was meant for testing purposes and had nothing to do with the production system.
- The reconnaissance exercise was critical, mainly because not every vulnerability is always straightforward and easily identifiable. Sometimes it may take extensive digging to discover whether sensitive information, such as the one identified in the assignment, is a true secret or a test case.
- The assignment offered various insights, including:

- Learning how to conduct passive reconnaissance using GitHub search and keywords.
- I discovered the difference between encrypted secrets and plain text.
- I learned the significance of EJSON and how it can be used to encrypt secrets in code.
- I gained knowledge on EJSON public and private keys, including the purpose of each and the information that should be kept secure.
- The assignment was critical in helping me learn that files placed in the test/spec/example directories as test cases usually contain mock data and not actual production credentials.
- It helped me develop better skills in distinguishing between a potential vulnerability and a test case.
- The assignment enabled me to develop the required report while also learning the proper way of submitting vulnerability reports to the bug bounty platform.
- I learned the importance of avoiding assumptions and double-checking what I find before reporting vulnerabilities to the bug bounty platform.
- I gained more insight into how the bug bounty platform works, including grading the severity of the identified bugs based on the provided evidence.
- I have learned that responsible security research entails being honest about the reports, including being able to say that you do not know if the issue is present or not when the evidence is not available or does not support it.

8. Video Demonstration

- A video demonstrating the complete assessment process has been recorded. The demonstration includes:
  - Selection of the target repository.
  - Passive reconnaissance methodology.
  - GitHub keyword searches performed.
  - Identification of the EJSON_PRIVATE_KEY.
  - Observation of EJSON-encrypted (EJ[1:]) values.
  - Explanation of why the finding was ultimately determined to be part of a test case.
  - Preparation of the draft HackerOne report.
- Google Drive Link:
  Video Demonstration and Assignment Snapshots